

FOR TECHNICAL REVIEW — NOT AN IMPLEMENTATION ORDER

Pre-Launch Technical Review Package

Developer Validation Draft

Prepared for the XPLRA development team • Requested by Luis Venegas • 19 September 2026

Requested outcome

Review the AI-assisted findings against the actual code and release environment. Confirm, qualify or dispute each finding with evidence; identify missing context and proposed priorities. This package does not approve a rewrite, authorize deployment, expand MVP scope or establish production exploitability.

The reviewed snapshots

Component	Repository / branch / full commit
Mobile + gameplay Functions	XPLRA/xplra · dev-U 0da62ed8b9492c10c805672b76b322a7df7eeb0e
Admin + HTTP API	XPLRA/xplra-backend · terabitDev 6dcabc6de528c41bba0dd7c3fdeeea03a7c081f9

These are audit snapshots, not a statement of the currently deployed or latest revision. Please provide release build/configuration identifiers and any relevant fix SHAs. [S1 §1; S2 §1; S5 baseline]

What the cross-repository review changes

Source locations are now clearer. Gameplay validators, XP grants, recovery, social commands, the push sender and Firestore rules were found in xplra/functions/src and the mobile repository. They are no longer generally “missing source.” Storage policies, effective deployment and infrastructure evidence remain unresolved. [S5 Decision Brief; §16]

Authority needs review across both implementations. The audit identifies different progression writers/contracts and specific validation, administrative-entry and rules concerns. Server-side execution does not by itself establish correct authorization or reward eligibility. [S5 §§5, 13–15]

Existing work should be retained where valid. Some XP unit tests exist. The reports do not justify replacing Flutter, Firebase or TypeScript to address the observed boundaries. Review enabled-MVP behavior first. [S1 §10; S5 §§13, 17–18]

Evidence boundary: this document consolidates supplied AI audit reports; it is not a new repository audit. “STATICALLY VERIFIED” and “CROSS-REPO VERIFIED” remain source-level labels. The supplied audits report no live exploitation, build/device testing or restore execution. Developer assessment and release readiness remain unestablished. [S1 §1; S5 method]

02 / REVIEW PACKAGE

First review: exposure and authority

Please prioritize the deployment applicability and source interpretation of these items. These are review groups, not approved remediation tickets.

RV-01 Deployment and system ownership

Audit observation. The mobile repository also contains gameplay Functions and Firestore rules. Normal mobile gameplay was not found calling the Next.js API; shared Firestore data and the contribution proxy connect the implementations. Deployment alignment is unknown.

Developer review. Confirm the release topology, deployed SHAs/builds, Firebase projects, service owners and enabled entry points. Identify changes since these snapshots and any additional writers or controls outside both repositories.

S5 §§1, 16, 19; XR-14 | Reported code anchors: [M01](#) · [M02](#) · [B01](#)

RV-02 Administrative access and password reset

Audit observation. The reports identify sensitive Next.js handlers without consistent caller/role guards, untrusted administrator labels/actor fields, and a password-reset route that returns a recovery link. The separate mobile recovery flow does not protect that admin route.

Developer review. Is each path deployed and reachable? Show the actual authentication, operation authorization and trusted provisioning controls, including any external protection. Confirm whether the reset response still exists in the current release.

S5 §§4, 13; BA-R1/R2/R9; XR-11 | Reported code anchors: [B07](#) · [B09](#) · [B03](#)

RV-03 Quest mode and completion requirements

Audit observation. Server validators exist, but the cross-repository audit reports caller-selected quest modes and completion paths that do not prove the required dwell or answer count. This qualifies the earlier description of gameplay as server-authoritative.

Developer review. Confirm the control flow and intended mode/state contract. Supply isolated tests showing that wrong-mode, incomplete-dwell and no-answer requests are rejected while valid quests still complete. Clarify which modes are enabled for MVP.

S5 §§5–8, 15; XR-01; CM-05 | Reported code anchors: [M08](#) · [M09](#) · [M10](#)

RV-04 Direct Firestore privacy and protected fields

Audit observation. The supplied rules permit a public one-document user query and leave some progression/role projections writable, while denying direct canonical xp_total writes. The audit also flags answer-bearing configuration/session reads and unbound report-actor fields.

Developer review. Compare these exact source permissions with deployed rules. Validate whole-document privacy, protected field ownership, answer secrecy and reporter identity using positive and negative rules tests. Distinguish protected XP balance from mutable display projections.

S5 §§3, 8, 12, 20; XR-03/04/16 | Reported code anchors: [M02](#) · [M11](#) · [M68](#)

RV-05 Contribution approval into gameplay XP

Audit observation. The audit traces an unguarded admin approval proxy to the secret-protected gameplay grant Function. The upstream secret is not evidence that the original reviewer is authorized. Approval, reward and playable activation are separate steps.

Developer review. Confirm reviewer authorization before any upstream action, project/secret-binding metadata without secret values, and the current-versus-legacy review path. Explain approval without XP, activation, retries and partial-failure behavior.

S5 §§5, 12, 15; XR-02; CM-13–15 | Reported code anchors: [B17](#) · [M21](#)

03 / REVIEW PACKAGE

Progression and cross-system correctness

Please validate the intended contract as well as implementation. Distinguish a source discrepancy from an observed production failure.

RV-06 One authoritative progression contract

Audit observation. Gameplay uses xp_total and a nested player ledger; the admin writer uses xpTotal and a top-level ledger. Both write root level. Gameplay, admin preview and admin grants use different formulas; source_caps nesting and terminal-level handling also disagree.

Developer review. Identify the intended total, ledger, formula and configuration schema, which writers are active, and whether any path is legacy/disabled. Supply sanitized fixtures and version-parity evidence. Do not rebalance players or merge history without an agreed policy.

S5 §5, §§12–15; XR-05; CM-01–04/20 | Reported code anchors: [M13](#) · [M14](#) · [B10](#) · [B13](#) · [B14](#)

RV-07 Accounting, retries and actual award outcomes

Audit observation. Gameplay has deterministic idempotency, but the audit identifies pre-transaction balance reads, cap/date-policy concerns and completion-before-grant failure paths. Admin accounting uses a different dedupe path. UI/response fallbacks may imply nominal XP after an award fails.

Developer review. Explain existing guarantees and recovery mechanisms. Demonstrate distinct concurrent awards, retries after partial completion, cap boundaries and actual-award responses in isolation. Reconcile both histories before approving reversals, repairs or migration.

S5 §5, §§15, 20; XR-06/07; CM-15 | Reported code anchors: [M13](#) · [M10](#) · [M25](#) · [B10](#)

RV-08 Location freshness, auto-start and session lifecycle

Audit observation. Server radius, accuracy and dwell logic is present. Remaining reported gaps concern accepted-sample freshness, start-policy enforcement, duplicate starts and completion gates. Nearby background detection and ongoing validation pings use different execution paths.

Developer review. Confirm timing/entry/explicit-start policy and resume/cancel semantics. Provide controlled tests for stale samples, repeated entry, lost responses and supported-device suspension/offline behavior. Do not treat all location validation as client-side or manifest settings as runtime proof.

S5 §§6–10; XR-09; CM-06–08/24 | Reported code anchors: [M07](#) · [M08](#) · [M24](#) · [M26](#)

RV-09 Moderation, linked records and account deletion

Audit observation. Social Functions consume moderation status; inspected gameplay validators do not show the same check. Geography propagation can be partial. Account deletion spans several steps and does not cover all admin history, device registrations or media in the inspected implementation.

Developer review. Define intended suspension/ban effects, including active sessions, and identify external enforcement. Explain propagation recovery and approved deletion-versus-retention behavior across stores. Provide evidence before calling missing cleanup either a defect or intentional retention.

S5 §§4, 11–12, 20; XR-08/10/12/16 | Reported code anchors: [B18](#) · [M45](#) · [B21](#) · [M55](#)

No automatic economy or data change

Review must identify the intended progression policy, active writers and history before any rebalance, backfill, reversal or ledger consolidation is proposed for approval. Existing user identities and records are not to be silently reinterpreted. [S3 F4; S5 §5, 18]

04 / REVIEW PACKAGE

Release behavior and operational evidence

Not every placeholder is an MVP requirement. Confirm approved scope and reuse existing tests, fixes and controls before proposing additional work.

RV-10 Uploads, computation bounds and dependency review

Audit observation. Earlier source findings about media validation/publication and unbounded XP preview remain in scope. The audit flags the pinned Next.js 14.2.16 baseline against its cited vendor guidance; this package has not independently rechecked current advisories.

Developer review. Review admin and direct-mobile upload paths, deployed storage restrictions and server work limits. Confirm the actual dependency/runtime version, current advisory applicability and supported target, with regression evidence rather than a version bump alone.

S5 §13; BA-R3/R4/R8; S3 REM-R07-09 | Reported code anchors: [B26](#) · [B22](#) · [B27](#) · [M58](#)

RV-11 Mobile recovery and sensitive logging

Audit observation. Mobile recovery has server proof checks and is distinct from admin password reset. The cross-audit raises race/single-use concerns and a phone-account deletion assumption requiring tests. A mobile Apple identity-token debug print is reported; release exposure is unknown.

Developer review. Show atomic proof-consumption and replay tests, treatment of pre-existing phone-auth users, provider/MFA configuration and safe delivery/logging evidence. Preserve UID/provider associations and already approved recovery policy; identify any unresolved product decision.

S5 §4, §20; XR-11; BA-R18 | Reported code anchors: [M50](#) · [M54](#) · [M05](#)

RV-12 Release identity, background behavior and notifications

Audit observation. The frontend brief reports competing Android IDs/release signing declarations. Cross-repository review locates a real push sender, while token refresh, account-switch handling and tap routing need review. Signed entitlements and actual device behavior are unverified.

Developer review. Identify the active release build configuration and intended app IDs/signing. Supply signed-device evidence for background behavior, APNs/FCM, token rotation, account changes and notification navigation. Explain already-fixed differences from the audited snapshot.

S1 §§5–6, 9; S5 §§9, 11, 19; XR-13 | Reported code anchors: [M35](#) · [M37](#) · [M73](#) · [M74](#)

RV-13 Enabled MVP features versus placeholders

Audit observation. The reports identify unfinished QR verification and placeholder or incomplete referral, achievement, badge and streak award paths. Definitions, screens and older dormant code do not by themselves establish enabled reward functionality.

Developer review. Confirm each feature against the approved MVP scope. Supply implementation/deployment evidence for enabled functionality, or document its exclusion and inaccessible reward paths. This request does not ask the team to build every placeholder or post-MVP feature.

S5 §§6, 11, 16; XR-15; S1 §5 | Reported code anchors: [M01](#) · [M47](#) · [M48](#)

RV-14 Tests, operational recovery and release evidence

Audit observation. Some gameplay XP unit tests exist, qualifying the backend-only absence of tests. None of the supplied audits ran builds, tests, devices, production queries or restores. Deployment controls, backup coverage, monitoring and recovery remain unverified.

Developer review. Provide existing relevant results before proposing new work: source/build/config versions, test scope, environments, remaining failures and owners. Include isolated restore and reconciliation evidence, plus release/rollback procedures for the enabled MVP system.

S5 §§13, 19–21; XR-14; S3 REM-R25/R26 | Reported code anchors: [M76](#) · [M03](#)

05 / REVIEW PACKAGE

What to return

Use the separate editable response worksheet. One consolidated response per RV group is sufficient initially; split it only when findings need different dispositions.

Assessment and supporting evidence

Select: AGREE · PARTIAL · DISAGREE / FALSE POSITIVE · COVERED ELSEWHERE · FIXED AFTER SNAPSHOT · NEEDS TESTING. Separately record deployment applicability: DEPLOYED / ENABLED · NOT DEPLOYED / DISABLED · UNKNOWN. “Not deployed” describes exposure; it does not automatically invalidate the source finding.

For each group, include the code path and commit, redacted configuration/deployment evidence or test result; explain limitations. Propose any action, reviewer/owner and next checkpoint. Do not mark a finding closed solely because a UI prevents normal users from reaching it. [S5 §§13, 19–21]

Evidence packet: reuse existing materials

Packet	Requested evidence / original request IDs
Deployment & access	Deployed app/admin/Functions revisions, projects, build IDs, service owners, ingress and operation-level controls. DE-01/04/05.
Database & media policy	Effective Firestore rules/indexes; Storage rules, bucket permissions and path/visibility policies. DE-02/03.
Progression & gameplay	Sanitized configuration/data shapes; canonical XP policy; session, code/dwell, start, ban, contribution and activation contracts. DE-06/07/08.
Tests & signed clients	Existing isolated negative/concurrency/recovery fixtures/results, plus signed-device background/push and active build configuration. DE-09/10.
Identity & recovery	Provider/MFA settings, proof/replay tests, phone-account handling and delivery configuration metadata. DE-11.
Operations & scope	Backup/restore, retention/deletion, alerts and reconciliation evidence; extra award services only for claimed enabled features. DE-12/13.

Supply metadata, redacted exports and access-controlled evidence references—not passwords, reset links, bearer tokens, private keys, accepted code answers or secret values. The reports request isolated tests, not production exploitation, deliberate exhaustion or destructive recovery. [S5 §19; S3 §F]

How this becomes an agreed plan

First, reconcile the audit with the technical team’s response and deployed evidence. Next, separate accepted defects, externally covered items, changed implementations, unresolved questions and product decisions. Only then agree the enabled-MVP launch gates, proposed changes, dependencies and owners.

Source P0/P1 labels, acceptance criteria and S/M/L/XL estimates are proposals carried for traceability—not approved scope, promised effort or a final release decision. Prior product approvals should be reused; raise only unresolved questions about rewards, roles, recovery, moderation, validation, retention or feature inclusion. [S3 §G; S4 introduction; S5 §15]

Please flag any confirmed active exposure promptly for coordinated handling through the team’s security/change process, rather than waiting for every architecture question to be answered. This review request itself does not authorize production changes.

Traceability and source register

RV identifiers organize this review only. Keep the existing REM-R00–R26 and XR-01–XR-16 identifiers for technical tracking; do not create duplicate remediation workstreams.

Review group	REM-R ticket numbers	XR risk numbers
RV-01	00, 10	14
RV-02	01, 02, 03, 04	11
RV-03	06, 18, 19, 20	01
RV-04	03, 04, 10, 20	03, 04, 16
RV-05	02, 03, 06, 14, 23	02, 07
RV-06	06, 11, 15, 16, 17	05
RV-07	05, 12, 13, 14, 15, 16	06, 07
RV-08	18, 19, 21, 26	09
RV-09	22, 23, 24, 26	08, 10, 12, 16
RV-10	05, 07, 08, 09, 11	Local backend findings
RV-11	01, 26	11
RV-12	26	13
RV-13	00, 18, 20, 26	15
RV-14	25, 26	14

Included reference reports

ID	Source and role in this package
S1	Frontend Audit Handoff Brief — client/platform context; now supplied separately.
S2	Backend Audit Handoff Brief — backend-only summary, qualified by S5.
S3	Pre-Launch Backend Remediation Brief — provisional targets, priorities and decisions.
S4	Remediation Implementation Cards — original planning detail; not an approved backlog.
S5	Cross-Repository Architecture & Authority Audit — explicit source reconciliation and cross-boundary evidence.
S6	Full Backend Audit — earlier detailed source evidence and original risk register.

Reading precedence: use S5’s explicit reconciliations for cross-repository questions; retain S1/S2/S6 for their scoped evidence and S3/S4 as provisional planning. This is not independent verification of S5. Contrary code or deployment evidence should be recorded, not discarded.

S5 states that it used the recovered full frontend audit rather than the separately titled handoff. S1 is included here as additional supplied context; this package does not imply the cross-auditor originally saw it. No runtime execution is inferred from a generic reference to earlier checks.

Reference reports are copied unchanged under Reference_Reports/. Their C:/Users/... references are historical local paths, not portable attachments. The referenced ticket CSV and companion manifests were not uploaded and are not represented as included. Commit-pinned GitHub links require repository access; the links are report-supplied pointers, not code independently retrieved for this package.

Status: ready to request developer review. Technical acceptance, mitigation status, implementation approval and production readiness remain unestablished.